

Task 1 Governance Architecture and Stakeholder Map (20 marks)

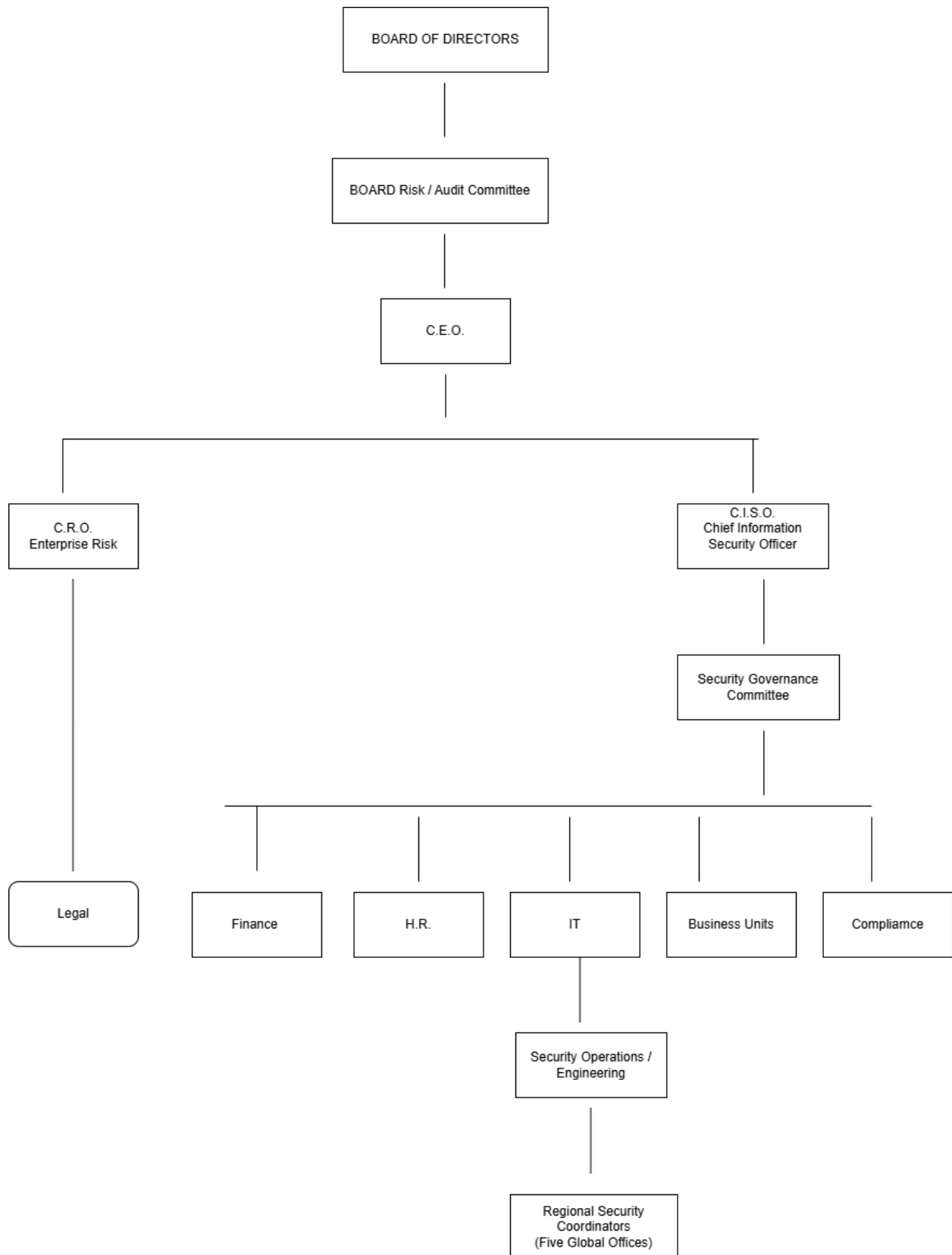
1. Governance Gap Assessment

Weakness	Description	Risk consequence
Security authority concentrated with IT Director	The IT Director currently acts as security owner, risk approver, and operational decision maker.	Creates conflict of interest, weak segregation of duties, and increases the likelihood that business risks are accepted without independent challenge.
Inconsistent security practices across business units	Different offices and departments make independent security decisions without common governance standards	Creates uneven security maturity, inconsistent controls, and increased exposure from weaker business areas.
Lack of defined security ownership and accountability	Roles such as risk owner, control owner, system owner, and approval authority are not formally assigned	Security failures may occur because responsibilities are unclear and teams assume another function owns the risk.
Absence of structured risk escalation process	Operational security issues do not follow a defined escalation path to executives or the Board.	Critical risks may remain unresolved for long periods and material incidents may not receive timely attention.
Security strategy is not integrated with business strategy	Cybersecurity decisions are mainly driven by IT requirements rather than organisational priorities.	Security investments may not support business growth, innovation objectives or regulatory obligations.
No formal security governance committee structure	There is no established forum where executives, risk owners and security leaders review cyber risks and strategic decisions.	Security decisions remain operational rather than business-driven, limiting alignment between cybersecurity and organisational objectives.

2. Stakeholder Map

Stakeholder	Governance Role	Authority	Information Needs	Contribution
Board of directors	Cybersecurity management and enterprise risk governance	Approves risk appetite, challenges management decisions, and provides strategic management	Cyber risk dashboard, major incidents, regulatory exposure, security maturity, emerging threats	Ensure cybersecurity receives appropriate strategic attention and accountability
CEO	Executive accountability for security outcomes	Owns business decisions involving risk acceptance and strategic priorities	Business impact of cyber risks, investment requirements, critical incidents	Ensures cybersecurity supports business objectives and organisational growth
CISO	Security governance leader	Defines security strategy, policies, standards and security roadmap	Threat intelligence, risk assessments, compliance status, security performance metrics	Leads the security programme, advises executives, and coordinates security activities
CRO	Enterprise risk integration	Provides risk methodology and challenges risk decisions	Cyber risk register, treatment plans, residual risk levels	Ensure cybersecurity risks are managed consistently with enterprise risk processes
Legal/Compliance	Regulatory and legal governance	Provides compliance interpretation and regulatory guidance	Privacy obligations, contracts, regulatory requirements, investigation evidence	Ensures security activities meet legal and regulatory expectations
Finance	Financial governance and investment management	Controls budget allocation and financial risk decisions	Security investment proposals, cyber loss exposure, cost-benefit analysis	Support prioritisation of security investments and evaluate financial impact
HR	Human-related security governance	Controls employee lifecycle processes	Awareness results, disciplinary cases, access lifecycle issues	Support security culture, training and employee accountability
IT	Security implementation and operations	Own technical controls and technology services	Security standards, vulnerabilities, architecture requirements	Implement controls, maintain systems and support operational resilience
Business unit	Business risk ownership	Own operational decisions and accept business risks within authority limits	Business-specific risks, security requirements, compliance obligations	Ensure security controls are adopted within business operations

3. Proposed Security Governance Organisation Chart



4. Consultant Justification

TechGlobal's current security governance model was suitable during its early growth phase but is no longer appropriate for an organisation with approximately 2,500 employees operating across five global offices. As the company expands, cybersecurity risks become increasingly interconnected with business operations, regulatory obligations, customer trust and financial performance. The proposed governance structure introduces clear accountability by separating security governance responsibilities from technology operations. Previously, the IT Director controlled security ownership, risk acceptance, and implementation decisions, creating excessive concentration of authority. The new model establishes the CISO as the independent security governance leader while allowing IT teams to remain responsible for technical implementation.

A formal Security Governance Committee creates a structured decision making environment where cybersecurity risks are evaluated from multiple perspectives, including business impact, regulatory requirements, financial implications, and operational priorities. This ensures security decisions are not treated only as technical issues but as enterprise risk decisions. The model also improves Board visibility by creating a defined reporting pathway from operational security teams through the CISO, CEO and Board Risk Committee. This enables directors to understand material cyber risks, make informed decisions and fulfil their oversight responsibilities.

The inclusion of CRO, Legal, Finance, HR and Business Unit leaders ensures cybersecurity becomes a shared organisational responsibility rather than an isolated IT function. The CRO provides alignment with enterprise risk management, Legal ensures regulatory obligations are considered, Finance supports investment prioritisation, HR manages human-related risks, and business leaders remain accountable for protecting their operational environments.

For a global technology organisation of TechGlobal's size, this governance model provides the necessary balance between central oversight and local flexibility. Global security policies and standards provide consistency, while regional teams maintain the ability to address local operational requirements. This approach supports business growth while reducing security risk through improved accountability, transparency, and decision-making discipline.